

closure_evidence_20260923

BOB-189 closure evidence — 2026-09-23

Defect

The §11.4.252 fail-open scanner's silent-default-return heuristic flagged 3 genuine fail-CLOSED sites inside `_is_safe_fetch_url` (an SSRF guard in `download-proxy/src/api/routes.py`) as fail-open — every call site gates on the return value and refuses (if not `X()`: `...; continue`), so acting on the finding naively would mean deleting an SSRF protection.

Fix

Call-site-aware discrimination in `classify_suppress`'s surrounding AST machinery (constitution submodule): a hit is suppressed only when EVERY call site of that bare function name in the file is refuse-shaped (escapes via `continue/break/return/raise`, anywhere at top level, not only as the first statement). Zero call sites or any ungated caller keeps the hit flagged (conservative-safe default, §11.4.201(4)). A suppressed hit prints as an honest NOTE citing the call-site evidence, never silent.

Independent verification (coordinator, from clean shell)

```
$ nice -n 19 ionice -c 3 bash constitution/scripts/gates/  
cm_dangerous_combination_fail_closed_mutation_test.sh  
[189 fixtures including L82-L86 BOB-189 discrimination-boundary  
cases]  
    META PASS — ... META_EXIT=0
```

Direct invocation against the real current routes.py:

```
^ $ bash constitution/scripts/gates/
cm_dangerous_combination_fail_closed.sh --root <copy> --max-depth
1 --quiet
    FAIL – silent default return ... :376
x    FAIL – swallowed exception ... :529
    FAIL – swallowed exception ... :1244
△ NOTE – CALL-SITE-GATED ... :1352
△ NOTE – CALL-SITE-GATED ... :1364
△ NOTE – CALL-SITE-GATED ... :1385
    FAIL – 3 fail-open anti-pattern hit(s) found
```

The 3 `_is_safe_fetch_url` SSRF sites now print as honest NOTES (down from FAIL); the 3 unrelated, out-of-scope findings remain correctly flagged — confirming the fix is precisely scoped and doesn't over-suppress.

The item's originally-named `_qbit_add_succeeded` false positives no longer exist (independently reconfirmed) — that function was refactored into a bare delegation with no try/except of its own since the item was filed.

Status

Fixed. Pushed to all 6 constitution-submodule remotes (commit eba38e8). Closed by coordinator after independent re-verification.